

Clase 279 — NIST Cybersecurity Framework

Parte: **14 — GRC, riesgo y cumplimiento** · Fuente: *NIST Cybersecurity Framework 2.0 (NIST)* 

Duración estimada: **90 min** · Nivel: **Intermedio**

Objetivo

Dominar el NIST Cybersecurity Framework (CSF) 2.0, el marco voluntario más usado en el mundo para organizar y comunicar la postura de ciberseguridad. Al terminar sabrás usar sus seis funciones, construir un perfil actual y objetivo, evaluar niveles de implementación (Tiers) y usar el CSF como lenguaje común entre lo técnico y la dirección.

Resultados de aprendizaje

Al finalizar, el alumno podrá:

1. **Enumerar** y explicar las seis funciones del CSF 2.0.
2. **Construir** un perfil actual (as-is) y un perfil objetivo (to-be).
3. **Evaluar** el Tier de implementación de una organización.
4. **Realizar** un análisis de brechas (gap analysis) entre perfiles.
5. **Priorizar** acciones de mejora usando el CSF como hoja de ruta.

Temas

#	Tema	Por qué importa
1	Núcleo del CSF (Core)	Estructura de funciones, categorías y subcategorías
2	Función GOVERN (nueva en 2.0)	Integra gobernanza en el marco
3	IDENTIFY, PROTECT, DETECT, RESPOND, RECOVER	Ciclo de vida de la defensa
4	Tiers (1–4)	Grado de rigor y madurez
5	Perfiles actual y objetivo	Base del plan de mejora
6	Informative references	Mapeo a 27001, CIS, 800-53
7	CSF vs. ISO 27001	Cuándo usar cada uno

Definiciones y características

- **CSF Core:** jerarquía de Funciones → Categorías → Subcategorías → Referencias informativas. *Clave:* describe *qué* lograr, no *cómo*.
- **GOVERN (GV):** función nueva en 2.0 que abarca estrategia, roles, política y supervisión de riesgo. *Clave:* sitúa la gobernanza en el centro.

- **IDENTIFY (ID)**: conocer activos, riesgos y contexto. *Clave*: no puedes proteger lo que no conoces.
- **PROTECT (PR)**: salvaguardas para limitar el impacto. *Clave*: controles preventivos.
- **DETECT (DE)**: descubrir eventos y anomalías. *Clave*: visibilidad y monitorización.
- **RESPOND (RS) / RECOVER (RC)**: contener y restaurar tras un incidente. *Clave*: resiliencia operativa.
- **Tier**: nivel de rigor de la gestión de riesgo (1 Parcial → 4 Adaptativo). *Clave*: es madurez, no una nota de examen.

Herramientas y preparación

- El documento oficial *NIST CSF 2.0* (descarga gratuita en nist.gov/cyberframework).
- El *CSF 2.0 Reference Tool* de NIST para explorar el Core y exportar a Excel/JSON.
- Hoja de cálculo para el perfil y el gap analysis.
- Opcional: los *Quick Start Guides* de NIST por tipo de organización (pyme, gestión de riesgo empresarial).

Laboratorio guiado (ejercicio aplicado)

Vas a construir un perfil CSF 2.0 para "Ferretería del Sur S.A.".

1. **Descarga** el CSF 2.0 Reference Tool y exporta las subcategorías de las 6 funciones a una hoja de cálculo.
2. **Selecciona un subconjunto** representativo: 3 subcategorías por función (18 en total), por ejemplo GV.RR-01 (roles), ID.AM-01 (inventario de activos), PR.AA-01 (identidades), DE.CM-01 (monitorización de red), RS.MA-01 (gestión de incidentes), RC.RP-01 (plan de recuperación).
3. **Perfil actual**: puntúa cada subcategoría de 0 (no implementado) a 4 (optimizado) según la situación de la empresa. Sé honesto: muchas estarán en 1–2.
4. **Perfil objetivo**: define el nivel deseado en 12 meses para cada una.
5. **Gap analysis**: calcula la diferencia (objetivo – actual) y ordena por mayor brecha.
6. **Tier global**: valora si la organización está en Tier 1 (Parcial) o Tier 2 (Informado por riesgo) y justifica.
7. **Hoja de ruta**: prioriza las 5 acciones con mayor brecha y mayor impacto, y asigna responsable y trimestre.
8. **Mapeo cruzado**: para 3 subcategorías, anota el control ISO 27001 o CIS equivalente usando las referencias informativas.

Ejercicios

1. Explica qué aporta la función GOVERN que no existía en CSF 1.1.
2. Clasifica estas actividades por función: inventariar activos, desplegar EDR, restaurar backups, revisar logs de SIEM.
3. Define en tus palabras cada uno de los 4 Tiers con un ejemplo.
4. Convierte un gap analysis en tres objetivos SMART.
5. ¿Puede una organización estar en Tier 4 en DETECT y Tier 1 en RECOVER? Justifica.
6. Compara CSF y ISO 27001: ¿cuál certifica y cuál comunica?

Reto verificable

Entrega un **perfil CSF 2.0** con al menos 18 subcategorías (3 por función), con puntuación actual y objetivo, gap analysis ordenado y una hoja de ruta de 5 acciones priorizadas con responsable y plazo.

Criterio de aceptación: las 6 funciones están representadas, cada acción de la hoja de ruta se justifica por una brecha concreta, y al menos 3 subcategorías están mapeadas a su control ISO/CIS equivalente.

 Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
Tratar el Tier como una "nota" a maximizar	El Tier objetivo depende del apetito de riesgo, no siempre es 4
Perfil actual inflado	Sesgo de deseabilidad; puntúa con evidencia real
Ignorar la función GOVERN	Es el eje de 2.0; intégrala desde el inicio
Copiar el Core entero sin priorizar	Inmanejable; selecciona subcategorías relevantes al riesgo
Confundir CSF con marco certificable	CSF no certifica; para eso está ISO 27001

 Preguntas frecuentes

-  **¿CSF sustituye a ISO 27001?** No, se complementan. CSF es un lenguaje flexible para comunicar y planificar; ISO 27001 certifica un sistema de gestión. Muchas organizaciones usan ambos.
-  **¿Qué cambió en la versión 2.0 (2024)?** Se añadió la función GOVERN, se amplió el alcance a todas las organizaciones (no solo infraestructura crítica) y se reforzaron cadena de suministro y métricas.
-  **¿Es obligatorio en EE. UU.?** Es voluntario en general, aunque muchas agencias y contratos federales lo exigen de facto.
-  **¿Sirve para una PYME?** Sí; NIST publica Quick Start Guides específicas para pequeñas empresas y gestión de riesgo empresarial.

 Referencias

- NIST Cybersecurity Framework 2.0. <https://www.nist.gov/cyberframework>
- NIST CSF 2.0 Reference Tool. <https://csrc.nist.gov/projects/cybersecurity-framework/filters>
- NIST SP 800-53 Rev.5 — Security and Privacy Controls. <https://csrc.nist.gov/pubs/sp/800/53/r5/upd1/final>
- NIST SP 800-37 Rev.2 — Risk Management Framework. <https://csrc.nist.gov/pubs/sp/800/37/r2/final>
- (ISC)² CISSP Official Study Guide, dominio 1.

 Siguiente clase

Clase 280 - Controles CIS